

```
jacksonisaac@Jackson's Macbook ~$ env x='() { :;; echo vulnerable' bash.old -c 'echo hello'
vulnerable
hello
jacksonisaac@Jackson's Macbook ~$ env x='() { :;; echo vulnerable' sh.old -c 'echo hello'
vulnerable
hello
jacksonisaac@Jackson's Macbook ~$
```

Figure 1: The Shellshock vulnerability test

have bash running on them. Bash is installed as the system's default command line interface on many Linux and UNIX-based systems including Mac OS X. Based on the source code analysis of bash, about *25 years' worth of bash versions* since the early 1990s through version 4.3 (in Linux systems) and version 3.2.48 (in Mac OS X) seem to be vulnerable. The vulnerability might exist beyond these versions as well, based on recent reports about the patches not being entirely effective.

It would be very difficult to patch all the systems that are affected by this bug, as bash is used in almost all devices like modems, home routers, Internet of Things (IoT) with embedded Linux, Web servers and devices connected to the Internet. Although bash is not directly exposed to the Internet, software or an application that is connected to the Internet can be used to run commands through bash internally on the vulnerable systems.

Operating systems that bash supports allow environment variables to be set, which are dynamic in nature. The attacker can attach some malicious code to this environment variable that will be executed once the variable is received. The attacker can force an application to send this specially crafted environment variable to bash, and it could be used to create a self-replicating worm.

According to a survey by Netcraft, we can conclude that almost half the online servers are running on Apache, which in turn runs on Linux machines and would have bash installed. As a result of this, half the Internet is vulnerable to the Shellshock bug.

The most likely method to attack systems is through Web servers using CGI (Common Gateway Interface), which is widely used to generate dynamic Web content. CGI scripts can be used to execute bash commands without the need for any authentication.

The bash continues processing commands after the function definition, resulting in what is generally termed as 'code injection attack'. The problem is that the auto-import function parser runs past the end of the function definition and keeps executing the codes. An attacker can gain access through this, and can then compromise and infect other systems on the network. FreeBSD and NetBSD have disabled auto import functions in bash version 3.2.54 onwards, by default, to prevent future vulnerabilities.

According to Wikipedia, the security firm Incapsula noted 17,400 attacks on more than 1,800 Web domains, originating from 400 unique IP addresses on September 26, 2014; 55 per cent of the attacks originated from China and the United States. By September 30, the website performance firm CloudFlare said it was tracking approximately 1.5 million attacks and

probes per day related to the Shellshock bug.

Updating bash

In order to reduce your system's vulnerability to Shellshock, you can update bash in the OS you are using. Here's how you can do so.

Build bash from source on Mac OS X

Here I'll show you how to rebuild bash from source on Mac OS X, as the patch released by Apple Inc is not entirely effective against some of the vulnerabilities.



Note: Make sure your Mac has Xcode and Xcode command line tools installed.

Open up *Terminal*.App and type in the following commands.
(i) To download the bash tarball and apply patches:

```
$ curl https://opensource.apple.com/tarballs/bash/bash-92.tar.gz | tar xzf -
```

```
$ cd bash-92/bash-3.2
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-052 | patch -p0
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-053 | patch -p0
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-054 | patch -p0
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-055 | patch -p0
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-056 | patch -p0
```

```
$ curl https://ftp.gnu.org/pub/gnu/bash/bash-3.2-patches/bash32-057 | patch -p0
```

Here, we need to add patches starting from 052 and apply the later patches subsequently.



Note: Bash 3.2 patches 52, 53, and 54 correspond to Bash 4.3 patches 25, 26, 27 and so on.

(ii) Rebuild bash: After applying the patches in the bash-3.2 folder, we move up to the bash-92 folder and build the source:

```
$ cd ..
$ xcodebuild
```

(iii) Back up and update default bash: Now let us check the